



YAHOO BREACH

How the Limited Adherence to The NIST CSF Caused an Incident



JUNE 25, 2025
AYDEN ROMULUS

Part A

Describe the purpose, structure, and key updates introduced in version 2.0 of the framework.

The purpose of The National Institute of Standards and Technology's Cybersecurity Framework 2.0 (NIST CSF 2.0) is to assist organizations by providing guidelines, best practices and resources on how to manage and protect against cybersecurity-related risks.

Though NIST's CSF 2.0 outlines what outcomes organizations can implement, it must be noted that it does not develop in detail how they can be achieved. To help with this, NIST offers other resources to aid with examples on their official website (National Institute of Standards and Technology [NIST], 2024, p. 1).

CSF 2.0, priorly known as the "Framework for Improving Critical Infrastructure Cybersecurity" is updated with new information about governance and supply chains. The framework has also been updated to contain Implementation Examples and Informative References which can be accessed by organizations at any time (NIST, 2024, p. iv).

Version 2.0 comprises of the following:

- **CSF Core:** often referred to as the "nucleus", it provides a hierarchy of functions, categories and subcategories to describe each desirable cybersecurity outcome (NIST, 2024, p. 1).
- **CSF Organizational Profiles:** can be regarded as benchmarks for comparing an organization's status with an ideal one in accordance with the CSF Core's goal (NIST, 2024, p. 1).

- **CSF Tiers:** a scale used to characterize an organization's acceptance and execution of cybersecurity practices (NIST, 2024, p. 1).

Cybersecurity Framework Core

To understand how the core is designed, it provides a list of functions and their categories followed by their subcategories. This means each function can be visualized like this:

Function #1		
	Category #1	
		Subcategory #1
		Subcategory #2
	Category #2	
		Subcategory #1
		Subcategory #2

Located in the CSF 2.0 document, attached is an excel spreadsheet with detailed information like the format stated above.

The CSF Core Functions

Govern (GV) – This function prioritizes plans, goals, policies and procedures, regulations, monitoring and communication between the organization and its stakeholders which revolves around strategies to mitigate risks. Essentially, it ensures that organizations have a clear plan for dealing with cybersecurity risks by assisting with the development of the other functions (NIST, 2024, p. 3).

Identify (ID) - This function explains identifying what assets an organization is protecting and what risks are involved in the process. Identify works alongside Govern as the risk management strategy is required (NIST, 2024, p. 3). The function is asking, do we understand what we are safeguarding and the risks involved with them?

Protect (PR) – This function deals with implementing systems designed to secure assets and mitigate the likelihood of a cyber incident occurring in the future. These are usually measures put in effect before an attack or intrusion (NIST, 2024, p. 4).

Detect (DE) – This function deals with the unfortunate event of discovering and realizing any cybersecurity attacks that have occurred and affected the organization and initiates any incident response and recovery efforts (NIST, 2024, p. 4).

Respond (RS) – This function is the actions an organization executes which occur directly after a cybersecurity incident. Usually used to identify compromised assets, analyze the attack and report to stakeholders on steps the organization will take to defuse the situation (NIST, 2024, p. 4).

Recover (RC) – This function tells us how an organization restores day-to-day operations after a cybersecurity incident has occurred (NIST, 2024, p. 4).

All the functions play a major role in protecting organizations. According to the CSF 2.0 document, it is stated that the CSF Functions can be viewed as a wheel where they are all interconnected (NIST, 2024, p. 4). The functions Govern, Identify, Protect and Detect must all be continuously active while Respond and Recover must always be prepared and executed when a cyber incident has occurred (NIST, 2024, p. 5).

FUNCTION 1: PROTECT (PR)

a. How does this function inform your understanding of how and why the incident occurred?

The Yahoo breach displayed a large amount of evidence of cybersecurity failures that can be seen across all six NIST CSF functions, in this case specifically the Protect function.

Yahoo is an American web portal that offers several services, including Yahoo Mail, Yahoo News, Yahoo Finance, Yahoo Sports, and their search engine, Yahoo Search (Wikipedia contributors, 2020). The organization continues to hold the record for the highest number of affected people worldwide after suffering two of the largest data breaches ever documented in 2013 and 2014.

It was reported that over three billion users were compromised with all including personal information such as account names, email addresses, telephone numbers, date of birth, hashed passwords and encrypted and unencrypted security questions obtained through manipulated web cookies. (Wikipedia contributors, 2024)

Initially, to safeguard user data, Yahoo's database utilized a complex hashing algorithm "bcrypt," which is thought to be difficult to crack. The remaining passwords used obsolete algorithms like "MD5", which were simple to crack. This inconsistency would turn out to be a critical vulnerability in their system, which intensified brute-force password cracking. (Wikipedia contributors, 2024)

It is without a doubt that Yahoo failed to comply with the Protect Function of NIST's CSF with evidence of weak encryption in which brute-force password cracking was executed on the MD5 hashing algorithm. There is also evidence of insufficient access controls, in which attackers were able to manipulate cookies to bypass authentication (PKWARE, 2016; StrongDM, 2025).

b. What policies or controls were put in place to mitigate the incident? Justify your assumptions.

NIST's CSF Functions all have categories with safeguards that organizations should use to mitigate risks. However, they were not followed during the breaches. Below will be listed the categories of the Protect function which should have been followed:

- **Identity Management, Authentication, and Access Control (PR.AA):**
“Access to physical and logical assets is limited to authorized users, services, and hardware and managed commensurate with the assessed risk of unauthorized access” (NIST, 2024, p. 19). Evidence of failure: weak password hashing (MD5) and stolen cookie-generation code which allowed unauthorized access.
- **Awareness and Training (PR.AT):** “The organization's personnel are provided with cybersecurity awareness and training so that they can perform their

cybersecurity-related tasks” (NIST, 2024, p. 20). Evidence of failure: insufficient employee training to recognize threats like forged cookies.

- **Data Security (PR.DS):** “Data are managed consistent with the organization’s risk strategy to protect the confidentiality, integrity, and availability of information” (NIST, 2024, p. 20). Evidence of failure: lack of encryption for stored passwords and sensitive user data.

- **Platform Security (PR.PS):** “The hardware, software (e.g., firmware, operating systems, applications), and services of physical and virtual platforms are managed consistent with the organization’s risk strategy to protect their confidentiality, integrity, and availability” (NIST, 2024, p. 20). Evidence of failure: insecure code repositories which allowed attackers to steal authentication mechanisms.

- **Technology Infrastructure Resilience (PR.IR):** “Security architectures are managed with the organization’s risk strategy to protect asset confidentiality, integrity, and availability, and organizational resilience” (NIST, 2024, p. 20). Evidence of failure: no safeguards to prevent lateral movement post-breach.

Unsecured infrastructure, inadequate access restrictions, and weak encryption caused violations in all categories of the Protect function (PR.AA, PR.AT, PR.DS, PR.PS, and PR.IR).

FUNCTION 2: RESPOND (RS)

- a. How does this function inform your understanding of how and why the incident occurred?**

Yahoo did not implement countermeasures and did not notify its users of the attack until two years later. The accounts were then found to be for sale on a darknet market in June of 2016. Yahoo knew of the problem, but at the time, only informed users about it rather than reset their account passwords. Additionally, Yahoo acknowledged during public disclosures that they were aware of the attack on their network but had not realized the full scope of the incident until much later. (Wikipedia contributors, 2024)

According to Wikipedia contributors (2024), Yahoo disclosed in December 2016 that a 2013 breach had compromised one billion accounts. In October 2017, this estimate was updated to reveal that all three billion Yahoo accounts had been affected.

It is obvious that Yahoo failed to comply with the Respond Function of NIST's CSF with evidence of no incident response plan for quick containment and poor communication during disclosure, worsening financial and/or reputational harm (Je, 2016; StrongDM, 2025).

- b. What policies or controls were put in place to mitigate the incident?**

Unfortunately, there is no found evidence that NIST's Respond function was followed, which should be implemented in the event of an attack and never overlooked in the framework. Below will be defined the Respond function's categories as well as their alignment to the incident which should have been followed.

- **Incident Management (RS.MA):** "Responses to detected cybersecurity incidents are managed" (NIST, 2024, p. 22). Evidence of failure: Yahoo did not execute an incident response plan and delayed disclosure of the breach for three years.
- **Incident Analysis (RS.AN):** "Investigations are conducted to ensure effective response and support forensics and recovery activities" (NIST, 2024, p. 22). Evidence of failure: inadequate forensic analysis to identify root causes.
- **Incident Response Reporting and Communication (RS.CO):** "Response activities are coordinated with internal and external stakeholders as required by laws, regulations, or policies" (NIST, 2024, p. 22). Evidence of failure: poor and inconsistent communication with stakeholders which led to Securities Exchange Commission (SEC) fines and acquisition devaluation.

- **Incident Mitigation (RS.MI):** “Activities are performed to prevent expansion of an event and mitigate its effects” (NIST, 2024, p. 22). Evidence of failure: no containment of forged cookie misuse for three years.

All categories of the Response function (RS.MA, RS.AN, RS.CO, RS.MI) were neglected and the event displayed evidence of delayed response, insufficient analysis, and failed mitigation.

To conclude, fundamental faults in all six NIST CSF functions are most clearly shown by the Yahoo breach, especially in PROTECT and RESPONSE. The attack might have been lessened by following CSF 2.0 procedures, which include strong encryption, ongoing monitoring, incident response preparation and many others. This breach is an example which displays how the NIST’s CSF is cemented today and is greatly encouraged not to be ignored.

Part B

Create a checklist with 10 controls or policies (5 for each of the 2 functions named above).

Below is a checklist of 10 controls or policies – 5 for the Protect function and 5 for the Respond function – relevant to the Yahoo breach. Each control addresses the faults and lessons learned from the incident.

Protect Function

1. **Enforce Strong Encryption for Data at Rest and in Transit:** Yahoo used an outdated and ineffective hashing algorithm (MD5) that was very susceptible to brute force attacks. Use algorithms like “bcrypt,” “argon2,” and “bcrypt” instead. Also encrypt all sensitive data including security questions and answers (ISBuzz, 2016; Yahoo, 2022; Yahoo Information Security, n.d.).
2. **Implement Multi-Factor Authentication (MFA):** The attack could have been prevented by implementing an MFA system. Since many users reuse their passwords across websites, they are at risk of being compromised if one site is breached. Encourage the use of unique passwords and implement MFA to prevent unauthorized access, even if credentials are compromised (Yahoo, 2022; Yahoo Information Security, n.d.).
3. **Restrict Access based on Least Privilege:** Ensure that users only have access required for their responsibilities by enforcing stringent identity and access control policies. When access is no longer required, swiftly revoke it (Yahoo, 2022; Yahoo Information Security, n.d.).

4. **Regular Vulnerability Scanning and Patch Management:** Continuous security testing is necessary. Never assume that the organization's current security is sufficient. Scan for vulnerabilities and apply patches promptly before attackers take advantage of them (Yahoo, 2022; Yahoo Information Security, n.d.).

5. **Comprehensive Security Awareness Training:** Provide annual security training that is required of all staff members in the organization, emphasizing social engineering, phishing, and safe handling of private information (Yahoo, 2022; Yahoo Information Security, n.d.).

Respond Function

1. **Maintain and Test an Incident Response Plan:** To guarantee efficient and well-coordinated action during security incidents, develop, record, and test a formal incident response plan on a regular basis (Cyberark, 2024; Kumar, 2023).

2. **Establish 24/7 Security Operations Center (SOC) Monitoring:** Operate a SOC to monitor, detect, and respond to security events in real-time, leveraging automated alerting and escalation procedures (Yahoo, 2022; Yahoo Information Security, n.d.).

3. **Conduct Post-Incident Forensic Analysis:** Conduct in-depth forensic investigations following an incident to determine its impact, scale, and underlying causes as well as to guide future preventative measures (Cyberark, 2024; Kumar, 2023).

4. **Timely Breach Notification and Communication:** Implement clear processes for prompt internal and external communication, including regulatory and customer notifications following a breach (Cyberark, 2024; Kumar, 2023).

5. **Continuous Improvement of Response Procedures:** Update response plans and controls following each incident in light of lessons learned to ensure the organization can adapt to evolving threats (Cyberark, 2024; Kumar, 2023; Yahoo Information Security, n.d.).

These controls, if enforced, would significantly reduce the likelihood and impact of the breach by strengthening both preventive and responsive cybersecurity measures.

Later on, Yahoo made major efforts toward aligning their operations with the NIST CSF 2.0 after its breach, especially in incident response, recovery, stakeholder communication, and continuous improvement.

References

- Cyberark. (2024, March 14). *How to Align Your Security Strategy with NIST Cybersecurity Framework 2.0*. Cyberark.com; How to Align Your Security Strategy with NIST Cybersecurity Framework 2.0. <https://www.cyberark.com/resources/it-security-audit-and-compliance/how-to-align-your-security-strategy-with-nist-cybersecurity-framework-2-0>
- EvolvingSysadmin. (n.d.). *Practicum/pages/respond/respond.md at main · EvolvingSysadmin/Practicum*. GitHub.
<https://github.com/EvolvingSysadmin/Practicum/blob/main/pages/respond/respond.md>
- Je. (2016, September 24). *Privacy Commission Advisory on Yahoo Breach*. National Privacy Commission. <https://privacy.gov.ph/privacy-commission-advisory-on-yahoo-breach/>
- Kumar, S. (2023, August 17). *Incident handling and Response - YAHOO UNAUTHORIZED ACCESS (DATA BREACH).pdf*. SlideShare.
<https://www.slideshare.net/SathishKumar960827/incident-handling-and-response-yahoo-unauthorized-access-data-breachpdf>
- ManageEngine, communications@manageengine.com. (2022). *ManageEngine Log360*. ManageEngine Log360. <https://www.manageengine.com/log-management/compliance/nist-csf-protect-function.html>
- National Institute of Standards and Technology. (n.d.). *The NIST Cybersecurity Framework (CSF) 2.0 Core With Withdrawn CSF 1.1 Elements This document presents the Functions, Categories, and Subcategories of the CSF 2.0 Core along with the indicators for CSF 1.1 Categories and Subcategories that were withdrawn from CSF 2.0*. Retrieved June 25,

2025, from https://www.nist.gov/system/files/documents/2024/03/25/The_NIST_CSF_2-0_Core_With_Withdrawn_CSF_1-1_Elements.pdf

National Institute of Standards and Technology. (2024). The NIST cybersecurity framework (CSF) 2.0. *The NIST Cybersecurity Framework (CSF) 2.0, 2.0(29)*.
<https://doi.org/10.6028/nist.cswp.29>

PKWARE. (2016, October 5). *The Yahoo Breach: Four Lessons | Blog*. [Www.pkware.com](http://www.pkware.com).
<https://www.pkware.com/blog/the-yahoo-breach-four-lessons>

ISBuzz, T. (2016, September 24). *Security Experts Respond To Yahoo Breach*. Information Security Buzz. <https://informationsecuritybuzz.com/security-experts-respond-yahoo-breach/>

StrongDM, T. (2025, March 18). *Yahoo Data Breach: What Happened and How to Prevent It*.
Strongdm.com; StrongDM, Inc. <https://www.strongdm.com/what-is/yahoo-data-breach>

Wikipedia Contributors. (2020, January 12). *Yahoo!* Wikipedia; Wikimedia Foundation.
<https://en.wikipedia.org/wiki/Yahoo>

Wikipedia Contributors. (2024, August 29). *Yahoo data breaches*. Wikipedia; Wikimedia Foundation. https://en.wikipedia.org/wiki/Yahoo_data_breaches

Yahoo. (2022, December 5). *YAHOO TECHNICAL AND ORGANISATIONAL SECURITY MEASURES | Yahoo*. Legal.yahoo.com.
<https://legal.yahoo.com/ie/en/yahoo/terms/securitymeasures/index.html>

Yahoo Information Security. (n.d.). *Yahoo Information Security*. https://cdn.prod.website-files.com/6721939c8726e5c8dc6b9f96/6721939c8726e5c8dc6ba169_yahoo-paranoids-information-security.pdf